

Guía de Campo — Auditoría de Seguridad · Consultorio Médico

ISO 27001:2022 · Ley 25.326 (Protección de Datos Personales) · Ley 26.529 (Derechos del Paciente)

Gaspar Peralta — Auditor en formación ISO 27001 Lead Auditor PECB

Guía de apoyo para el relevamiento presencial o por videollamada. Contiene los activos a identificar y los 28 controles agrupados en 7 categorías, en versión resumida: qué preguntar/observar, nivel de riesgo y referencia normativa (ISO 27001 Anexo A + legislación argentina). Usar junto con el checklist digital interactivo para cargar resultados, madurez (0-3) y observaciones detalladas de cada ítem.

 **Riesgo alto** — indagar siempre

 **Riesgo medio** — si el tiempo lo permite

 **Riesgo bajo** — si sobra tiempo

Escala de madurez a registrar en el checklist digital: **0 Inexistente** · **1 Informal** · **2 Definido** · **3 Gestionado**

Activos a identificar (relevar en los primeros minutos)

Preguntar qué sistemas usan, dónde guardan la información y con qué equipos trabajan, antes de entrar al checklist de controles.

Activo	Tipo	Criticidad	¿Confirmado?
Historias clínicas digitales	Información	Crítica	☐ Sí ☐ No ☐ ?
Historias clínicas en papel	Físico	Crítica	☐ Sí ☐ No ☐ ?
Sistema de gestión de turnos	Software	Alta	☐ Sí ☐ No ☐ ?
PC / equipos del consultorio	Físico	Alta	☐ Sí ☐ No ☐ ?
Credenciales de acceso al sistema	Información	Alta	☐ Sí ☐ No ☐ ?
Router / red WiFi	Físico	Media	☐ Sí ☐ No ☐ ?
Disco externo / backup	Físico	Alta	☐ Sí ☐ No ☐ ?
Correo electrónico	Servicio	Media	☐ Sí ☐ No ☐ ?

Otros activos no listados: _____

Categoría 1 — Datos de pacientes

☐ **1.** ¿Los datos de pacientes están en sistemas con acceso restringido? **[ALTO]**

ISO: A.5.12 **Ley:** Ley 25.326 Art.12

Qué mirar: Verificar usuario/contraseña en el sistema digital. El papel también cuenta.

Notas: _____

☐ **2.** ¿Solo el personal autorizado puede ver las historias clínicas? **[ALTO]**

ISO: A.5.15 **Ley:** Ley 26.529 Art.2

Qué mirar: ¿Quién accede: solo el médico, también recepción? ¿Hay criterio definido?

Notas: _____

☐ **3.** ¿Saben qué datos recopilan y dónde exactamente los guardan? **[MEDIO]**

ISO: A.5.9 **Ley:** Ley 25.326 Art.8

Qué mirar: DNI, obra social, diagnósticos, medicación. ¿Existe un registro/inventario?

Notas: _____

[] 4. ¿Las HC en papel están separadas del área de acceso general? **[MEDIO]**

ISO: A.7.3 Ley: Ley 26.529 Art.14

Qué mirar: ¿Archivo o cajón accesible a cualquiera, o con algún control físico?

Notas: _____

[] 5. ¿Tienen criterio sobre cuánto tiempo conservan los datos? **[BAJO]**

ISO: A.5.12 Ley: Ley 26.529 Art.15

Qué mirar: Las HC deben conservarse mínimo 10 años. ¿Lo saben y aplican?

Notas: _____

Categoría 2 — Accesos y usuarios

[] 1. ¿Médico y recepción tienen usuarios individuales en el sistema? **[ALTO]**

ISO: A.5.16

Qué mirar: O comparten un login: sin usuario propio no hay trazabilidad de acciones.

Notas: _____

[] 2. ¿Las contraseñas son únicas y no se comparten verbal/por escrito? **[ALTO]**

ISO: A.5.17

Qué mirar: Buscar post-its, cuadernos con claves, o si recepción conoce la del médico.

Notas: _____

[] 3. ¿Las contraseñas tienen un mínimo de complejidad? **[MEDIO]**

ISO: A.5.17

Qué mirar: No pedir que las digan. ¿Usan nombre del consultorio, '1234', fecha nac.?

Notas: _____

[] 4. Si se fuera la recepcionista hoy, ¿cambiarían sus accesos ya mismo? **[ALTO]**

ISO: A.5.18 Ley: Ley 25.326 Art.9

Qué mirar: Procedimiento de baja de accesos. ¿Existe aunque sea informal?

Notas: _____

[] 5. ¿El sistema de turnos tiene acceso diferenciado del de HC? **[MEDIO]**

ISO: A.8.5

Qué mirar: O todo está en la misma plataforma con el mismo usuario.

Notas: _____

[] 6. ¿Las pantallas se bloquean solas cuando no se usan? **[MEDIO]**

ISO: A.7.7

Qué mirar: O quedan abiertas si el médico va a atender a otra sala.

Notas: _____

Categoría 3 — Copias de seguridad

[] 1. ¿Realizan backups del sistema digital de historias clínicas? **[ALTO]**

ISO: A.8.13 Ley: Ley 26.529 Art.15

Qué mirar: Sí/no, frecuencia (diario/semanal/nunca) y quién es el responsable.

Notas: _____

[] 2. ¿Dónde se guardan? ¿Separados del equipo principal? **[ALTO]**

ISO: A.8.13

Qué mirar: En la misma PC no sirve. ¿Disco externo, nube, servidor separado?

Notas: _____

[] 3. ¿Alguna vez probaron recuperar información de un backup? **[MEDIO]**

ISO: A.8.13

Qué mirar: Un backup no probado puede estar corrupto o incompleto sin saberlo.

Notas: _____

[] 4. ¿El papel tiene alguna copia o registro alternativo? **[BAJO]**

ISO: A.8.13 **Ley: Ley 26.529 Art.14**

Qué mirar: Si se pierden/destruyen las HC en papel, ¿hay algo para reconstruir?

Notas: _____

Categoría 4 — Equipos y red

[] 1. ¿Los equipos tienen antivirus activo y actualizado? **[ALTO]**

ISO: A.8.7

Qué mirar: No solo instalado: licencia vigente, sin alertas pendientes.

Notas: _____

[] 2. ¿El sistema operativo está actualizado con parches? **[MEDIO]**

ISO: A.8.8

Qué mirar: SO desactualizado = vulnerabilidades públicas. ¿Update automático?

Notas: _____

[] 3. ¿La red WiFi del consultorio está separada de la de pacientes? **[MEDIO]**

ISO: A.8.20

Qué mirar: Una sola red = pacientes en el mismo entorno que los datos médicos.

Notas: _____

[] 4. ¿El router tiene la contraseña por defecto cambiada? **[ALTO]**

ISO: A.8.20

Qué mirar: Las contraseñas de fábrica son públicas. ¿Alguna vez la cambiaron?

Notas: _____

[] 5. ¿Usan software con licencia válida? **[MEDIO]**

ISO: A.8.19

Qué mirar: Software pirata = vector de malware. ¿Windows/Office originales?

Notas: _____

Categoría 5 — Seguridad física

[] 1. ¿Las pantallas no son visibles desde la sala de espera? **[MEDIO]**

ISO: A.7.7 **Ley: Ley 26.529 Art.2**

Qué mirar: Si el monitor da hacia la sala, otro paciente puede ver los datos.

Notas: _____

[] 2. ¿El archivo de HC en papel está bajo llave / área restringida? **[MEDIO]**

ISO: A.7.3 **Ley: Ley 26.529 Art.14**

Qué mirar: ¿Cualquiera que entra al consultorio accede a las carpetas?

Notas: _____

[] 3. ¿El consultorio queda cerrado con llave sin personal presente? **[MEDIO]**

ISO: A.7.1

Qué mirar: ¿Equipos encendidos y accesibles si salen a almorzar un rato?

Notas: _____

[] 4. ¿Hay control de quién ingresa al área de equipos y archivos? **[BAJO]**

ISO: A.7.2

Qué mirar: ¿Puede entrar cualquier paciente a la zona de la PC?

Notas: _____

Categoría 6 — Gestión de incidentes

[] 1. ¿Saben qué harían si detectan robo/pérdida de datos? **[ALTO]**

ISO: A.5.24 **Ley: Ley 25.326 Art.12**

Qué mirar: ¿Hay procedimiento informal? ¿Saben que puede haber obligación de notificar?

Notas: _____

[] 2. ¿Tienen un contacto técnico de confianza para emergencias? **[MEDIO]**

ISO: A.5.24

Qué mirar: Si el sistema falla o hay un virus, ¿a quién llaman?

Notas: _____

[] 3. ¿El personal conoce nociones básicas de seguridad (phishing, etc.)? **[MEDIO]**

ISO: A.6.3 **Ley: Ley 25.326 Art.9**

Qué mirar: ¿Alguna vez hablaron del tema? ¿Reconocen un email de phishing?

Notas: _____

[] 4. ¿Saben qué hacer ante un correo o programa sospechoso? **[MEDIO]**

ISO: A.6.3

Qué mirar: ¿Práctica establecida o actúan por intuición en el momento?

Notas: _____

Categoría 7 — Cumplimiento legal

[] 1. ¿Los pacientes firman consentimiento informado de datos? **[ALTO]**

ISO: A.5.31 **Ley: Ley 25.326 Art.6**

Qué mirar: Obligatorio bajo Ley 25.326: qué datos, con qué fin, quién accede.

Notas: _____

[] 2. ¿Están inscriptos como responsables de base de datos ante la DNPDP? **[ALTO]**

ISO: A.5.31 **Ley: Ley 25.326 Art.21**

Qué mirar: La Ley 25.326 exige inscripción ante el organismo de control.

Notas: _____

[] 3. ¿El personal tiene compromiso formal de confidencialidad? **[MEDIO]**

ISO: A.6.6 **Ley: Ley 25.326 Art.10**

Qué mirar: Aunque sea una cláusula simple firmada en el contrato de trabajo.

Notas: _____

[] 4. ¿Los datos se comparten con terceros (labs, obras sociales)? **[MEDIO]**

ISO: A.5.31 **Ley: Ley 25.326 Art.11**

Qué mirar: Si se comparten, ¿hay consentimiento? ¿Se envía por email sin cifrar?

Notas: _____

[] 5. ¿Tienen web/formulario de turnos con política de privacidad? **[BAJO]**

ISO: A.5.31 **Ley: Ley 25.326 Art.6**

Qué mirar: Si recopilan datos por web, la política de privacidad es obligatoria.

Notas: _____

